ASSESSMENT TOOL II- ASSIGNMENT

COURSE CODE: ITA14 **COURSE NAME: Ethical Hacking**

COURSE OUTCOME COVERED

CO1: Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

ASSIGNMENTS QUESTIONS

1. A company hires you to test its network but gives you only a one-line email authorization with no defined scope. Halfway through testing, you discover a critical vulnerability in a system that wasn't mentioned in the email. Do you exploit it to prove impact? Justify your answer using ethical hacking principles.
2. You are conducting a penetration test and discover that the client's production database contains real customer financial data. Your test plan calls for exploiting a SQL injection vulnerability. How do you proceed without causing harm, and what precautions should have been taken before the engagement began?
3. During a black-box penetration test, you accidentally trigger a denial-of-service condition on a live production server, causing an outage. Walk through what you should have done to prevent this and what your responsibility is now.
4. A client asks you to test their systems but insists you not inform their IT department, wanting to test the team's real-world detection capability. What ethical and practical risks does this create, and how would you structure the engagement to protect yourself?
5. You're asked to perform a "red team" exercise versus a "vulnerability assessment." Using a real-world scenario of a bank wanting to test physical and digital security, explain how your approach, ethics, and rules of engagement would differ between the two.
6. While testing a web application, you find a vulnerability that could allow you to access other clients' data hosted on the same shared server. This is outside your contracted scope. What do you do, and how does this scenario illustrate the limits of ethical hacking engagements?
7. A junior tester on your team wants to use automated exploitation tools without fully understanding what they do, "because it's faster." Using this scenario, explain the risks of tool-dependent hacking and the professional standards expected of an ethical hacker.

8. Your client's competitor secretly offers you money to share findings from a penetration test you conducted for the client. Analyze this scenario in terms of professional ethics, confidentiality, and potential legal consequences.
9. A 16-year-old finds a flaw in their school's grading portal and quietly emails the administration instead of exploiting it. Classify this individual using standard hacker categorizations and justify your reasoning.
10. An employee, angry after being denied a promotion, uses their legitimate system access to leak internal documents to a journalist. Is this "hacking"? Analyze the actor's classification, motive, and the ethical/legal implications.
11. A security researcher publicly releases a working exploit for a vulnerability before the vendor has issued a patch, arguing that public pressure is the only way to force a fix. Discuss whether this qualifies as ethical hacking, and where this person falls on the hacker spectrum.
12. A nation-state-sponsored group breaches a hospital's systems to disrupt operations during a geopolitical conflict. Analyze this scenario across the categories of hacker types and explain why classification matters for response and law.
13. A person with no malicious intent scans random IP addresses on the internet "just to see what's out there" without permission. Argue both sides: is this person a "grey hat," and what ethical line have they crossed, if any?
14. Two people independently discover the same zero-day vulnerability. One reports it to the vendor; the other sells it on a dark web marketplace. Compare and contrast their classifications, motivations, and the consequences each might face.
15. A company employee is asked by management to secretly access a colleague's email account to gather evidence of misconduct, using company-owned credentials. Is this employee acting as an "ethical hacker"? Defend your position.
16. An AI-powered bot automatically probes IoT devices for default passwords and reports vulnerable devices to a public database without owner consent. Analyze whether the creator of this bot fits any traditional hacker classification, and what new categories might be needed.
17. You're performing an authorized penetration test and discover evidence that an employee of the client company is engaged in a separate, unrelated crime (e.g., embezzlement) unrelated to your scope. What are your ethical obligations, and how do they interact with your contractual scope?
18. A client asks you to test only certain departments, but you strongly suspect the departments excluded from scope contain the greatest security risk (possibly deliberately hidden by executives). Discuss the ethical tension between contractual boundaries and your professional duty to protect the organization.
19. During a social engineering assessment, you successfully manipulate a receptionist into revealing sensitive information by pretending to be a grieving relative of an employee. Evaluate the ethics of this pretext, considering psychological harm versus test realism.
20. You discover a vulnerability so severe that exploiting it, even briefly, could crash critical hospital patient-monitoring systems. Your contract requires "full exploitation to

confirm impact." How do you ethically resolve this conflict between contractual obligation and patient safety?

21. Your firm offers a discount to clients who agree to let you reuse "anonymized" data from their penetration test in a public case study or training material. Analyze the ethical issues around consent, anonymization, and confidentiality in this business model.
22. You are asked to test the security awareness of employees by sending a phishing email that impersonates a company layoff announcement, since it's proven to get high click rates. Discuss the ethical boundaries of social engineering tests and psychological impact on staff.
23. A fellow ethical hacker on your team wants to keep a "personal copy" of exploit code and access credentials discovered during a client engagement "in case it's useful later." Analyze the ethical and professional violations in this scenario.
24. You are contracted by a company to test its systems, but during recon you realize the company's core business model itself may be operating a scam that harms consumers. Do professional ethics require you to report this, and to whom, given your role is purely technical?
25. You are hired by a US-based company to test servers that are physically hosted in another country with different (and less protective) cybersecurity laws. Analyze the jurisdictional and legal issues you must resolve before starting the engagement.
26. Midway through a penetration test, the client's CEO verbally tells you to "go ahead and test that system too," but it isn't in the signed Statement of Work. Explain the legal risks of proceeding, referencing the concept of authorization and applicable computer misuse laws.
27. You discover, during an authorized test, a backdoor that appears to have been planted by a previous (unauthorized) attacker who is still actively using it. What are your legal obligations regarding evidence handling, reporting, and potential involvement of law enforcement?
28. A client terminates your penetration testing contract mid-engagement due to a business dispute, but you still have active reverse shells and access credentials on their systems. Explain, step by step, what legal and ethical actions you must take immediately.
29. An ethical hacker signs a contract with vague scope language ("test the network") and later exploits a cloud-based third-party service integrated with the client's systems. The third party threatens legal action. Analyze where liability may fall and how proper scoping and legal documentation could have prevented this.
30. A government asks a security firm to hack into a foreign company's servers "in the national interest," without a formal legal warrant applicable across borders. Discuss the legal and ethical grey areas this creates for the hackers involved, referencing relevant legal frameworks like the Computer Fraud and Abuse Act (or equivalent).
31. You are asked to sign an NDA and a "get out of jail free" authorization letter before a physical penetration test (attempting to break into a building). During the test, local police detain you before you can produce the letter. Explain what legal protections such authorization documents provide, and their limitations in real time.

32. A company's Terms of Service prohibit "unauthorized testing" of their systems, but a security researcher argues that responsibly probing publicly accessible endpoints without causing damage should be legal under public interest research exceptions. Analyze this argument using real-world legal precedent or debate.
33. You discover a critical zero-day vulnerability in widely-used medical device software during an authorized test. The vendor is unresponsive for 90 days despite multiple attempts to contact them. Using a responsible disclosure framework, explain your next steps and justify the timeline.
34. A security researcher publicly tweets details of a vulnerability in a popular banking app within hours of discovering it, without contacting the bank first, citing "the public has a right to know." Analyze this against standard disclosure practices and the potential real-world consequences.
35. You report a vulnerability to a company through their official bug bounty program, but the company threatens legal action against you instead of paying the promised reward, claiming you "exceeded authorized scope." Discuss the disclosure and legal risks researchers face, and how to mitigate them beforehand.
36. During a coordinated disclosure process, the vendor asks you to delay public disclosure indefinitely with no fixed patch timeline, citing "business reasons" unrelated to the technical fix. As the researcher, how do you balance ethical disclosure obligations against vendor pressure?
37. You find a vulnerability affecting an open-source library used by thousands of downstream applications. Disclosing to the maintainer alone won't reach all affected parties quickly. Design a disclosure strategy that balances speed, safety, and coordination across the ecosystem.
38. A company offers you a "hush payment" larger than their bug bounty reward, on the condition you never disclose the vulnerability, even after it's patched. Analyze the ethical implications of accepting this offer versus standard responsible disclosure.
39. You discover a vulnerability while testing one client's system, but the flaw actually exists in a third-party software product used by thousands of other organizations who are not your clients. Explain your ethical and practical disclosure obligations in this multi-party scenario.
40. A rival security researcher discloses a vulnerability you found first, taking public credit, after you had already privately reported it to the vendor under an embargo. Discuss the ethical norms around disclosure credit, embargoes, and how researchers should handle disputes like this professionally.

Code of Conduct:

I ____B.Vani(192472348)_ __ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Rubrics

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Problem Context	20	Clearly understands the problem and accurately identifies all data-handling requirements and operations	Good understanding with minor gaps	Basic understanding; some requirements unclear	Poor understanding or misinterpretation of the problem
Application of Concepts	30	Accurately applies appropriate data structures and algorithms to solve complex problems	Applies relevant concepts correctly with minor errors	Applies basic concepts with limited accuracy	Fails to apply appropriate concepts
Problem-Solving Approach	20	Logical, well-structured, and efficient approach	Mostly logical approach with minor gaps	Basic approach with some inconsistencies	Illogical or unclear approach
Accuracy of Solution	20	Completely correct code, output and complexity analysis with proper justification	Mostly correct with minor errors	Partially correct solution	Incorrect or incomplete solution
Clarity	10	Clear, well-organized, and properly explained solution	Understandable with minor clarity issues	Limited clarity and explanation	Poorly presented and difficult to understand

ANSWER FOR QUESTION 6

B.Vani (192472348)

1. Understanding the Situation

The ethical hacker is authorized to test a particular web application. During the assessment, a vulnerability is discovered that may allow access to information belonging to other clients using the same shared server. Those clients are not included in the contract. Therefore, although the weakness may be serious, the tester does not automatically have permission to investigate or access the other clients' information. The tester must distinguish between what is technically possible and what is legally and professionally authorized.

2. Immediate Action: Stop Beyond the Scope

The tester should stop before accessing or extracting the other client's data. Only the minimum activity needed to establish that a cross-client vulnerability exists should be performed. The tester should not download records, modify information, create accounts, or explore unrelated systems. This follows the principle of minimizing harm and prevents an authorized assessment from becoming unauthorized access.

Stopping at the boundary does not mean ignoring the vulnerability. It means recognizing that the finding may affect people who did not authorize the assessment. The tester should preserve the security of the environment while preparing a responsible report for the authorized client.

3. Document the Finding

The finding should be documented with the affected application, the condition that revealed the weakness, and its potential impact. Evidence should be limited to what is necessary. If information belonging to another client is accidentally visible, the tester should not collect large amounts of it. The report should clearly state that the potential cross-client access is outside the contracted scope.

4. Report Through the Proper Channel

The vulnerability should be reported promptly to the authorized client contact identified in the rules of engagement. The report should explain that the flaw may permit unauthorized access to other tenants on the shared server. If deeper testing is required, the tester should request explicit written authorization and an updated scope before continuing.

5. Example

Example: Company A hires a tester to assess its customer portal. The portal runs on a shared cloud environment also used by Company B. During testing, the tester notices that a request may return an object belonging to another tenant. The tester should not browse through Company B's records. Instead, the tester should preserve minimal evidence and report that tenant isolation may be broken. If further validation is needed, the client and relevant service provider should authorize it first.

6. Why the Vulnerability Is Serious

A cross-client access flaw can affect confidentiality and trust because one customer's security boundary may no longer separate its information from another customer's environment. The impact could include exposure of personal information, business records, credentials, or other sensitive material. However, the seriousness of the vulnerability does not give the tester unlimited permission to exploit it. The correct response is to communicate the risk accurately while keeping testing within authorized boundaries.

7. Authorization and Rules of Engagement

Authorization is the foundation of ethical hacking. Before testing begins, the tester should know the exact targets, permitted techniques, testing period, limitations, emergency contacts, and procedures for sensitive information. A Statement of Work and rules of engagement prevent uncertainty when unexpected vulnerabilities are discovered. In this case, permission to test Company A's application does not automatically authorize access to Company B's data simply because both environments share infrastructure.

8. Confidentiality and Data Protection

Confidentiality is especially important because the affected information belongs to a party that never authorized the assessment. An ethical hacker should use the least amount of information necessary to demonstrate the risk. For example, if a response accidentally displays another customer's identifier, there is no ethical reason to collect hundreds of additional records. The tester should protect any information unintentionally observed and report the exposure through the proper channel.

9. Responsible Communication and Remediation

The report should communicate the confirmed facts, possible impact, and scope limitation clearly. It can recommend remediation such as stronger tenant isolation, server-side authorization checks, access-control validation, secure session handling, and testing of boundaries between customer environments. These recommendations help the client correct the weakness without requiring the tester to perform unnecessary unauthorized exploitation.

10. If the Client Requests Further Testing

A request to continue should be formally documented when it affects systems or data outside the original scope. The revised authorization should identify the new targets, permitted actions, limits on data access, and responsible contacts. Written authorization protects both the client and the tester by creating a clear record of what was allowed. If appropriate authorization cannot be obtained, the tester should not continue the out-of-scope activity.

11. Why Scope Is a Limit

This scenario demonstrates that ethical hacking is not simply about finding a vulnerability and exploiting it as far as possible. Ethical hacking is bounded by authorization, scope, privacy, confidentiality, professional responsibility, and the duty to minimize harm. A tester may have the technical skill to cross a security boundary, but technical ability does not create permission to cross it.

12. Shared and Cloud Environments

The issue is especially important in shared servers, cloud platforms, managed databases, and multi-tenant applications. One customer's security weakness can sometimes expose another customer's information. In such environments, a tester must be careful because an action intended to help one client could unintentionally affect an unrelated organization. The proper response is controlled testing, responsible reporting, and coordination with authorized parties.

13. Importance of Minimizing Harm

An ethical hacker should select the least intrusive method that can establish a finding. If a vulnerability can be demonstrated without viewing real customer records, that approach is preferable. This protects the client, third parties, and the tester while still providing useful security evidence. The objective of a penetration test is to improve security, not to obtain as much information as technically possible.

14. Ethical Principles Applied

Authorization: Perform only activities that have been explicitly permitted. **Scope:** Respect the systems, users, data, and techniques defined in the engagement. **Confidentiality:** Protect information discovered during testing, especially third-party information. **Minimizing harm:** Use the least intrusive method needed to establish a finding. **Professional responsibility:** Report serious findings accurately and seek permission for additional work.

15. Practical Scenario

Suppose a web application uses an identifier to retrieve customer information. During an authorized test for Organization A, the tester notices that changing the identifier may expose an object associated with Organization B. The ethical tester should not enumerate many identifiers or download B's information. Instead, the tester should stop, record the minimum evidence needed, explain the possible tenant-isolation failure, and ask the authorized parties to investigate further. This demonstrates both technical awareness and ethical restraint.

16. Legal and Professional Risk

Going beyond the agreed scope can create serious professional and legal risks. The tester may face allegations of unauthorized access, breach of confidentiality, violation of contractual terms, or misuse of sensitive information. The client may also face liability if third-party information is exposed. Clear scoping and written authorization reduce these risks. Ethical hackers therefore have a responsibility to understand the boundaries of an engagement before and during testing.

17. Overall Decision

The correct decision is not to exploit the vulnerability against the other client. The tester should stop at the minimum point necessary to establish the issue, document it, protect any accidentally observed information, and report it to the authorized client. Further testing should occur only after appropriate written permission and scope changes are established.

18. Why Technical Ability Is Not Permission

A security professional may have the tools and knowledge needed to access a protected resource, but that does not make the access ethical. Authorization comes from the owner or another properly authorized party, not from the technical possibility of reaching the system. This distinction is one of the most important professional standards in ethical hacking.

19. Conclusion

This scenario shows that ethical hacking depends on more than technical skill. A professional tester must know when to stop. The fact that a vulnerability can provide access to another client's data does not mean that such access is authorized. Respect for scope, confidentiality, privacy, legal requirements, and the principle of minimizing harm keeps a penetration test ethical and professionally responsible.

In short, the ethical response is: **find the vulnerability, stop before accessing out-of-scope data, document the minimum evidence, report the risk, and obtain authorization before any further testing.** The central lesson is that technical capability is not the same as permission.